ECHO to Veritas - Master Handoff

Updated: 2026-11-09. Local branch: `main`, based on `9d761e6`. FreeLLMAPI is ECHO's verified primary conversational provider; deterministic commands, security gates and offline fallback are preserved; optional free browser speech is implemented. Phase 1 (conversational follow-up navigation) is complete and verified end to end.

Phase 1 - conversational follow-up navigation (2026-11-09)

The reported defect: after ECHO explained a page and offered to open it, an acceptance such as "okay take me there" only produced more prose. Returning text is not navigation, so the flow was rebuilt around a structured action.

Implemented:

1. **Structured offer lifecycle (server).** An offer is stored per ECHO session with its action ID, path and label, bound to the account `sub` and the role, and expiring after 60 s. `server/services/echo.ts` owns the store; revocation (logout / New chat) deletes it.
2. **Deterministic acceptance before the provider.** Cancellation, explicit replacement ("actually, open assignments instead") and deictic acceptance ("take me there", "open it", "yes please", "show me", "go there", "let's do that", "alright") are resolved before any FreeLLMAPI call, so the primary brain cannot answer them as fresh conversation.
3. **Only offered pages become pending.** The pending action is registered only when the displayed reply names exactly one allowlisted page (or uses the canonical "say open X and I'll take you there" offer). Two destinations yield a clarification, never a guess. Offers can only come from the fixed topic allowlist, never from model-generated URLs.
4. **Verification, not claims.** The `done` SSE event now carries `action: { type: 'navigate', actionId, path, label }`. The widget forwards it via `echo-widget:action`; `EchoAssistant` re-validates the path against `ECHO_PAGES` and the current role, moves the real router, and confirms only after both the React location and `window.location` match. Failures say so.
5. **Client deferral.** `EchoCommandSession` now exposes `hasPending`, and bare follow-ups bypass local recognition (which previously answered "could not match") whenever no local confirmation is active.
6. **Invalidation.** Offers expire after 60 s, are cleared by cancellation, by a different destination, by executing, by an unrelated reply, by a role change, by a second account, and by logout/reset.

Phase 2 - expandable and full-screen workspace (2026-11-09)

The widget panel now has three presentation modes on one mounted conversation: compact (380 px), expanded (min(720 px, 92vw)) and full screen (100vw x 100dvh with a centred readable column). The header gains a size button that cycles compact -> expanded -> full -> compact, with `aria-label` updated per mode ("Expand chat", "Full screen", "Restore size"). Escape restores compact before closing. The mode persists in `sessionStorage` (`echo-widget-mode-v1`) but the conversation, draft text, speech settings and pending server offers are never unmounted or reset by a mode change.

Verified in the browser regression at 1280x850: the panel widens on expand, fills the viewport in full screen, returns to compact, the URL never changes, and the message count is identical before and after each switch.

Microphone input, wake-word detection and admin data retrieval are **not** implemented; see "Remaining priorities" below.

What changed

1. **FreeLLMAPI is the primary brain.** Natural conversation goes to the FreeLLMAPI OpenAI-compatible gateway. `auto:reliable` is the default model and the gateway chooses the upstream route dynamically. OpenAI is ignored unless `ECHO_ALLOW_PAID_PROVIDER=true`; there is no mandatory paid provider.
2. **Security hardening.** ECHO sessions require a signed-in portal identity, are bound to the account `sub`, reject unapproved origins, use no shipped fallback secret, validate token format/expiry strictly, allowlist only `message` and `page`, bound all stores and rate-limit messages.
3. **Production security hardening (this release):**
- CORS origin allowlisting replaced reflected `origin: true` with explicit allowlist (403 on foreign origins, same-origin/preflight supported).
- Session secrets enforced: `SESSION_SECRET` ≥32 chars in production; `assertSessionSecretConfigured()` fails at startup if unset.
- `PORTAL_BOOTSTRAP_PASSWORD` required (≥16 chars) in production; seeds the principal's password; sample accounts receive random unusable hashes.
- Demo accounts (`/api/auth/demo-accounts`) return 404 in production; generic forgot-password response instead of password text.
- Production password policy: 12-char minimum for self-service changes; temporary one-time passwords for admin-created students/staff and resets.
- Login page: dev-only demo account panel; production shows "Secure sign■in — scrypt-hashed credentials and role■based access control."
- AppShell: dev-only instant role switcher hidden in production.
- StudentsStaffPage: shows temporary password in production enrollment/reset toasts.
- `server/utils/portalMode.ts`: production-mode detection.
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.
3. **Natural conversation.** Greetings, typos, follow-ups, page/role context, empathy, jokes, sensitive refusals, provider status and honest no-memory behavior are handled without inventing school records.
4. **Fuzzy commands.** Politeness, location questions, "pull up", "bring up", "where is" and location-aware navigation resolve locally. Compound plans are atomic and execute nothing if any part is unsupported. Ordinary prose with "and"/"or" stays conversational.
5. **Speech.** Free browser `speechSynthesis`, on/off, Stop, 0.8-1.5x speed, sentence streaming, no overlap, session-scoped settings and text fallback. A replacement provider can be registered at `window.EchoWidgetSpeechProviders`.
6. **Provider diagnostics.** Authenticated `/api/echo/provider` plus SSE `event: meta` reveal provider/model/route without keys, prompts or replies.

Verified provider evidence

Command: `ECHO_USE_DESKTOP_SETTINGS=true node tests/echo-freellm-provider.mjs`.

- Real local gateway, 292 models visible.
- Real multi-turn conversation; synthetic code `QX-7319` recalled on turn 2.
- Provider `freellmapi`, model `command-a-plus-05-2026`, route `cohere/command-a-plus-05-2026`; turns 1554 ms and 1580 ms.
- The live browser widget received the model-generated marker `PLUMAGE`.
- An earlier run routed to `qwen/qwen3.8-27b` via `groq`, confirming dynamic routing. Do not hardcode an upstream model in tests.
- Credentials were read from the existing FreeLLMAPI desktop store only with explicit opt-in, passed to the child server environment, never printed or written to the repository or browser.

Verified local checks

Check	Result
150 unit/integration tests: config, commands, conversation, navigation, security	PASS
`tsc --noEmit`	PASS
production `vite build`	PASS
full browser regression	PASS
live FreeLLMAPI provider test	PASS (previous release; not rerun here)

`tests/echo-navigation.test.ts` (new) drives the real router and asserts the `done.action` lifecycle: offer-then-accept, `open it`, `yes please`, `show me`, no-pending ambiguity, cancellation, 60 s expiry, explicit replacement, role change, session isolation, logout revocation, cross-account rejection and provider bypass. `tests/echo-browser.mjs` adds a real built-in-engine browser run (real widget, cookie session, real router) proving the URL changes from `/assignments` to `/attendance` only after acceptance, plus a forced `history.pushState` mismatch that must report "could not confirm".

Browser coverage includes login, typo commands, verified navigation feedback, context help, clipboard success/failure, Stop/reset/error recovery, speech on/off/speed/Stop/overlap/failure fallback, 390 px mobile, logout abort and second-account isolation. Browser regression uses fake SSE; only the opt-in test proves a real model.

Configuration contract

Server-only variables (never `VITE_*`, never frontend code):

```text
FREELLMAPI_BASE_URL=https://<public-https-gateway>/v1
FREELLMAPI_API_KEY=<secret>
FREELLMAPI_MODEL=auto:reliable
ECHO_ALLOW_PAID_PROVIDER=false
ECHO_SESSION_SECRET=<long random value>
SESSION_SECRET=<long random value>
PORTAL_BOOTSTRAP_PASSWORD=<16+ char production bootstrap secret>
```

- Development: with a key and no base URL, ECHO uses `http://127.0.0.1:31415/v1`; the FreeLLMAPI desktop app must be running.

- Production: explicit HTTPS only. Credentials in URLs, query strings, non-loopback HTTP and paths other than `/v1` are rejected.
- `PORTAL_BOOTSTRAP_PASSWORD` is required (≥16 chars) when `NODE_ENV=production` or running on Vercel; seeds the principal's password; sample accounts get random unusable hashes.
- Legacy `FREELMAPI_*` and `ECHO_MODEL_*` aliases still work.
- `/api/echo/provider` reports configured/reachable/model/base host; it never exposes the key.

Vercel status and required action

The deployed site still runs the old build. A model-only prompt received the old scripted welcome, so production is not provider-connected. Vercel cannot reach this PC's loopback gateway at `127.0.0.1:31415`.

To enable FreeLLMAPI in production:

1. Expose the gateway at a public HTTPS origin (an HTTPS tunnel or a hosted FreeLLMAPI-compatible gateway).
2. Add `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL`, `ECHO_SESSION_SECRET` and `SESSION_SECRET` in Vercel Project Settings -> Environment Variables.
3. Redeploy and sign in.
4. Check `/api/echo/provider` for `configured: true`, `reachable: true`.
5. Send a model-only prompt and confirm the SSE `meta` provider/model.
6. If the values are absent, the deployment intentionally uses deterministic fallback. HTTP 200 or Ready alone is not provider proof.

No credentials were exposed to frontend code. No paid provider is enabled.

Security status

`tests/echo-security.test.ts`: 135/135 PASS (including 6 portal-security gate tests). Fixed issues: anonymous issuance, unapproved origins, usable public fallback secret, malformed expiry, token suffix, unsupported fields, account binding, page-context injection, unbounded state and rate limiting.

New in this release:

- CORS origin allowlisting replaced reflected `origin: true` with explicit allowlist (403 on foreign origins, same-origin/preflight supported).
- Session secrets: `SESSION_SECRET` must contain at least 32 characters in production; `assertSessionSecretConfigured()` fails at startup if unset. `ECHO_SESSION_SECRET` added as alias.
- `PORTAL_BOOTSTRAP_PASSWORD` is required in production (`≥16 chars`); seeds random unusable hashes for sample accounts; only the bootstrap principal logs in.
- Demo accounts (`/api/auth/demo-accounts`) return 404 in production; generic forgot-password response instead of password text.
- Production password policy: 12-character minimum for self-service changes; temporary one-time passwords for admin-created students/staff and password resets.
- Login page: dev-only demo account panel; production shows "Secure sign■in — scrypt-hashed credentials and role■based access control."
- AppShell: dev-only instant role switcher hidden in production.

- StudentsStaffPage: shows temporary password in production enrollment/reset toasts.
- `server/utils/portalMode.ts`: production-mode detection (`NODE_ENV=production` or `VERCEL`).
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.

Residual, pre-existing or architectural:

- `server/utils/auth.ts` still uses a public default cookie secret when `SESSION_SECRET` is unset. Set it privately in production; it is the outer gate.
- Portal-wide reflected CORS remains at the API gateway level; ECHO origin checks are an additional gate, not a replacement.
- History/revocation are process-local; serverless instances do not share them.
- Stop cannot guarantee upstream cancellation/billing.
- Route confirmation covers view state, not lazy page-data loading.
- No physical-device or multi-browser matrix yet.

Key files

- `server/services/echo.ts`: authenticated router, account-bound sessions, origin/body/rate checks, SSE, page context.
- `server/services/echoConversation.ts`: natural conversation, provider priority, FreeLLMAPI/OpenAI config, status/probe, usage metadata.
- `server/index.ts`: authenticated `/api/echo/config`, `/api/echo/provider`, ECHO mount with cookie/Bearer portal identity.
- `src/lib/echoCommands.ts`, `src/lib/echoRecognition.ts`: registry, fuzzy commands, atomic plans, prose guards.
- `echo-web/widget/widget.js`: speech controller, credentials, page context, Stop/reset/copy.
- `tests/echo-navigation.test.ts`: 14 Phase 1 navigation lifecycle tests.
- `src/components/EchoAssistant.tsx`: `echo-widget:action` handler (allowlist, role check, router execution, observed-route confirmation).
- `tests/echo-security.test.ts`: 12 release gates.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.
- `tests/echo-conversation.test.ts`: 26 conversational/provider tests.
- `tests/echo-commands.test.ts`: 85 command tests.
- `tests/echo-browser.mjs`: full browser regression including speech.
- `tests/echo-freellm-provider.mjs`: opt-in real-provider verification.
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `server/utils/portalMode.ts`: production-mode detection.
- `.env.example`, `README.md`, `echo-web/README.md`: configuration contract.

Git and publication statePrevious release commit: `a49b9db8cacbb9c81490da4b209931ea45a1fa7`. Base for this work: `9d761e6`, rebased onto upstream `5cfd8da` (feat(portal): support PORTAL_DEMO_MODE) before pushing, so history is linear. Phase 1 navigation: `0013123` (feat(echo): execute offered navigation from conversational follow-ups). Phase 2 workspace modes: `6cef2ab` (feat(echo): add expanded and full-screen workspace modes). A documentation commit sits on top; use `git log --oneline` for the exact

current HEAD.

`npm run test:echo`: **150/150 PASS**.
`tsc --noEmit`: PASS.
`npm run build`: PASS (2045 modules).
`npm run test:echo:browser`: PASS, including the real built-in engine run.

Vercel did not auto-deploy the push. The workspace has no `.vercel` project link
or deploy hook. Manual Vercel publish or Git-integration reconnect is required.
After deploying, set environment variables (`SESSION_SECRET`, `ECHO_SESSION_SECRET`,
`PORTAL_BOOTSTRAP_PASSWORD`, `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`,
`FREELLMAPI_MODEL`, `ECHO_ALLOW_PAID_PROVIDER`) in Vercel Project Settings ->
Environment Variables and redeploy. Do not use `VITE_*` variables. After deploy,
verify `/api/echo/provider` reports `configured: true` and `reachable: true`,
and confirm a model-only prompt returns provider metadata. HTTP 200 or Ready
status alone is not provider proof. Do not force-push.

Remaining priorities (not implemented)

1. **Spoken input and wake word.** The widget has TTS only. A mic button using
the browser `SpeechRecognition` API is the next step; continuous "Echo" wake
word is limited by browser background-tab suspension and by the browser's own
speech service, so it must be documented as foreground-only. No audio is sent to
FreeLLMAPI today because there is no audio capture at all.
2. **Authorized data retrieval.** No `get_authorized_*` tools exist. The portal
API is read-only for the signed-in account and there is no documented grade
projection feature, so ECHO must not invent one. Any future tool layer must
reuse `req.auth`, scope by account, and keep model context free of raw records.
3. **Charts/tables in the workspace.** `recharts` is already a dependency, but
ECHO renders text only. Structured results need server-validated payloads first.
4. **File upload / multimodal input.** Not present.

Exact handoff paths

- Markdown:
`F:\Downloads\Veritas-Echo-Integration\echo-web\docs\ECHO-WEB-MASTER-HANDOFF.md`
- PDF:
`F:\Downloads\Veritas-Echo-Integration\echo-web\docs\ECHO-WEB-MASTER-HANDOFF.pdf`
- Backups: `F:\ECHO-Handoff\ECHO-WEB-MASTER-HANDOFF.md` and `.pdf`
- PDF generator: `python echo-web/docs/render_handoff.py` (requires reportlab;
output text is selectable/copyable).

Ready-to-copy continuation prompt

Continue ECHO/Veritas at `F:\Downloads\Veritas-Echo-Integration` on local `main`.
Read this handoff, `PENDING_WORK.md`, `RELEASE_VERIFICATION.md` and
`FUZZY_COMMANDS.md`, then inspect `git status`, `git log` and remotes. Phase 1
(conversational follow-up navigation with a verified, allowlisted route action)
and Phase 2 (compact/expanded/full-screen workspace) are complete. FreeLLMAPI is
still the primary conversational brain, with deterministic commands, security
gates, offline fallback and free browser speech.

Next priorities, in order: (1) microphone input and a foreground-only "Echo" wake word, documenting browser background-tab and vendor-speech limits; (2) authorized read-only data tools with account/role scoping and no raw records in model context; only then (3) tables/charts for validated results. The portal has no documented grade-projection feature, so do not invent one.

Do not recreate completed features, weaken tests or enable a paid provider. After any change, rerun `npm run test:echo` (150 tests), `npx tsc --noEmit`, `npm run build` and `npm run test:echo:browser`; the opt-in provider test needs the FreeLLMAPI desktop gateway. Keep the Markdown/PDF handoffs and `F:\ECHO-Handoff` copies current. Verify the deployed site after pushing; do not claim provider success from HTTP 200 or Ready alone.